KORE - Data Processing Agreement

Versione 1.1 - [data di pubblicazione]

Nomina a Responsabile del trattamento ai sensi dell'art. 28 del Regolamento (UE) 2016/679 - modello standard

VERSIONE	PUBBLICAZIONE	STATO
1.1	[data di pubblicazione]	ACTIVE

Questa è la versione corrente. Indirizzo permanente di questa versione: https://trust.kore-hub.otech.one/data-processing-agreement/v1-1/

Il presente Data Processing Agreement ("DPA") è identico per tutti i Clienti ed è richiamato dall'Order Form. I dati identificativi del Titolare e gli elementi specifici del trattamento (contatti privacy, retention, origine dei dati, eventuali dati relativi a condanne penali e reati, eventuali Sub-responsabili aggiuntivi) sono indicati nell'Order Form quale Allegato A-bis. La sottoscrizione dell'Order Form che richiama il presente DPA perfeziona la nomina di One Tech S.r.l. a Responsabile del trattamento.

Parti

Ruolo	Soggetto
Titolare	Il Cliente, come identificato nell'Order Form (denominazione, sede, C.F./P. IVA, contatto privacy/DPO)
Responsabile	One Tech S.r.l. ("ONE"), Via Gustavo Fara n. 35, 20124 Milano (MI), C.F./P. IVA 10071971211, contatto privacy: support@otech.one

Premesse

1. Il Titolare utilizza i servizi SaaS/API individuati nell'Order Form ("Servizi").
2. L'erogazione dei Servizi può comportare il trattamento da parte di ONE di dati personali per conto del Titolare.
3. Le Parti intendono disciplinare tale trattamento ai sensi dell'art. 28 GDPR. Il presente DPA non disciplina i trattamenti per i quali ONE determina autonomamente finalità e mezzi essenziali.

---

01 Definizioni e gerarchia

1.1 I termini del GDPR hanno il significato attribuito dal Regolamento (UE) 2016/679. "Sub-responsabile" indica il soggetto incaricato da ONE di specifiche attività di trattamento per conto del Titolare. Gli ulteriori termini con iniziale maiuscola hanno il significato loro attribuito dalle Condizioni Contrattuali Centralizzate.

1.2 Il DPA prevale sugli altri documenti contrattuali esclusivamente per le materie di protezione dei dati personali trattati da ONE quale Responsabile. Per livelli di servizio prevale lo SLA; per il resto l'Order Form e le Condizioni Contrattuali Centralizzate.

---

02 Oggetto, ruoli e finalità

2.1 Il Titolare nomina ONE Responsabile per i trattamenti descritti nell'Allegato A e ONE accetta la nomina.

2.2 ONE tratta i dati personali soltanto per erogare i Servizi e secondo le istruzioni documentate del Titolare. Non vende i dati personali, non li utilizza per contattare autonomamente gli interessati per finalità commerciali e non li impiega per addestrare modelli di intelligenza artificiale destinati a finalità proprie o di terzi, salvo specifica istruzione scritta del Titolare e previa verifica della relativa liceità.

2.3 ONE può operare quale autonomo Titolare per trattamenti distinti e propri, quali gestione dei rapporti commerciali e fatturazione, tutela dei propri diritti, prevenzione di frodi o abusi e sicurezza dei propri sistemi nella misura in cui ne

determini autonomamente finalità e mezzi essenziali. Tali trattamenti sono disciplinati dalle informative applicabili e non dal presente DPA.

03 Durata

3.1 Il DPA ha efficacia per la durata dei trattamenti svolti da ONE per conto del Titolare. Gli obblighi che per natura sopravvivono, inclusi riservatezza, restituzione/cancellazione e cooperazione su eventi anteriori alla cessazione, restano efficaci sino al loro adempimento.

04 Istruzioni documentate

4.1 Costituiscono istruzioni documentate il presente DPA e i relativi Allegati, le disposizioni dell'Order Form espressamente attinenti al trattamento, incluso l'Allegato A-bis, e le successive istruzioni scritte provenienti dai referenti autorizzati del Titolare.

4.2 Se una disposizione di legge impone a ONE un trattamento ulteriore, ONE ne informa preventivamente il Titolare salvo divieto di legge.

4.3 Se ONE ritiene che un'istruzione violi la normativa applicabile, ne informa senza ingiustificato ritardo il Titolare e, ove necessario per evitare una violazione, sospende l'esecuzione della sola istruzione interessata sino a conferma, modifica o revoca.

4.4 Istruzioni che richiedano sviluppi, modifiche architetturali, attività straordinarie o assistenza eccedente gli obblighi dell'art. 28 possono essere subordinate a tempi tecnici e corrispettivi ragionevoli previamente comunicati, fermo l'adempimento degli obblighi inderogabili.

05 Personale autorizzato e riservatezza

5.1 ONE limita l'accesso ai dati al personale che ne abbia necessità, secondo principi di least privilege e segregazione dei ruoli, e assicura che le persone autorizzate siano adeguatamente istruite e soggette a obblighi di riservatezza contrattuali o legali.

5.2 ONE mantiene misure organizzative ragionevoli di formazione e sensibilizzazione in materia di protezione dati e sicurezza coerenti con i ruoli svolti.

06 Sicurezza

6.1 ONE adotta e mantiene le misure tecniche e organizzative descritte nell'Allegato B, tenendo conto dell'art. 32 GDPR, dello stato dell'arte, dei costi di attuazione, della natura, ambito, contesto e finalità del trattamento e dei rischi per gli interessati.

6.2 ONE può aggiornare o sostituire le misure purché il livello complessivo di sicurezza non sia sostanzialmente ridotto. L'Allegato B descrive esclusivamente misure effettivamente operative o impegni espressamente contrattualizzati; roadmap e remediation interne non fanno parte del DPA salvo addendum scritto.

07 Sub-responsabili

7.1 Il Titolare autorizza in via generale ONE a ricorrere ai Sub-responsabili indicati nell'Allegato C, il cui elenco aggiornato è pubblicato nella sezione Sub-responsabili del Trust Center KORE (trust.kore-hub.otech.one).

7.2 ONE comunica l'intenzione di aggiungere o sostituire un Sub-responsabile almeno 15 giorni prima dell'avvio del relativo trattamento, mediante comunicazione al referente privacy del Titolare indicato nell'Order Form e pubblicazione nella sezione Sub-responsabili del Trust Center, salvo urgenze di sicurezza o continuità che rendano necessario un termine inferiore. Il Titolare può opporsi entro 10 giorni per motivi ragionevoli e documentati inerenti alla protezione dei dati.

7.3 In caso di opposizione, le Parti cooperano in buona fede per individuare una soluzione ragionevole. Se non è tecnicamente o commercialmente praticabile evitare il Sub-responsabile senza incidere sostanzialmente sul Servizio, il Titolare può cessare la sola componente direttamente interessata prima dell'avvio del nuovo trattamento, senza penali ulteriori rispetto ai corrispettivi maturati.

7.4 ONE impone ai Sub-responsabili, per le attività affidate, obblighi di protezione dati sostanzialmente equivalenti a quelli applicabili a ONE ai sensi dell'art. 28 GDPR e resta responsabile verso il Titolare dell'adempimento degli obblighi del Sub-responsabile nei termini previsti dalla legge.

08 Trasferimenti internazionali

8.1 ONE non trasferisce dati personali verso Paesi terzi o organizzazioni internazionali se non su istruzione del Titolare o tramite Sub-responsabili autorizzati e in presenza di un valido meccanismo del Capo V GDPR.

8.2 Ove necessario, ONE utilizza decisioni di adeguatezza, Clausole Contrattuali Tipo o altro strumento valido e adotta le misure supplementari ragionevolmente richieste dall'esito della valutazione del trasferimento. Le informazioni rilevanti sono riportate nell'Allegato C.

09 Assistenza al Titolare

9.1 Tenuto conto della natura del trattamento e delle informazioni a disposizione, ONE assiste il Titolare nell'adempimento degli obblighi relativi ai diritti degli interessati, sicurezza, DPIA e consultazione preventiva.

9.2 Se ONE riceve direttamente una richiesta relativa a dati trattati per conto del Titolare, la inoltra senza ingiustificato ritardo e non risponde nel merito salvo istruzione o obbligo di legge.

9.3 L'assistenza ordinariamente necessaria all'art. 28 è inclusa nei Servizi. Attività straordinarie, ripetitive o derivanti da istruzioni specifiche del Titolare possono essere oggetto di corrispettivo ragionevole se non dipendono da un inadempimento di ONE.

10 Violazioni dei dati personali

10.1 ONE notifica al Titolare una violazione dei dati personali di cui abbia acquisito conoscenza senza ingiustificato ritardo e comunque entro quarantotto (48) ore dalla conoscenza, fornendo le informazioni disponibili necessarie al Titolare per adempiere agli artt. 33 e 34 GDPR. Le informazioni possono essere integrate progressivamente.

10.2 La notifica di ONE non costituisce riconoscimento di responsabilità. Le decisioni sulla notifica all'Autorità o comunicazione agli interessati competono al Titolare, salvo obblighi autonomi di ONE previsti dalla legge.

11 Audit e dimostrazione della conformità

11.1 ONE mette a disposizione le informazioni ragionevolmente necessarie a dimostrare il rispetto dell'art. 28 GDPR. Ove disponibili, report indipendenti, certificazioni, questionari di sicurezza e documentazione equivalente sono utilizzati in via prioritaria per evitare audit duplicativi.

11.2 Il Titolare può effettuare un audit, direttamente o tramite terzo indipendente vincolato alla riservatezza, non più di una volta per anno, con almeno 15 Giorni Lavorativi di preavviso, durante l'orario ordinario e senza interferire irragionevolmente con i Servizi. Tali limiti non si applicano quando un audit ulteriore sia imposto da un'Autorità competente o ragionevolmente necessario a seguito di una violazione rilevante imputabile a ONE.

11.3 L'audit non può comportare accesso a dati di altri clienti, segreti commerciali, codice sorgente o informazioni la cui divulgazione comprometterebbe la sicurezza. I costi sono a carico del Titolare, salvo accertamento di un inadempimento materiale di ONE.

11.4 Eventuali diritti ulteriori richiesti da discipline settoriali o di vigilanza del Cliente, inclusi accessi diretti ai Sub-responsabili, sono applicabili solo se espressamente accettati da ONE in un addendum regolamentare e nella misura in cui ONE disponga dei corrispondenti diritti verso i fornitori interessati.

12 Restituzione e cancellazione

12.1 Alla cessazione dei Servizi, salvo diversa istruzione documentata impartita entro 30 giorni, ONE rende disponibili i dati nei formati standard previsti dal Servizio per un periodo di uscita di 30 giorni e successivamente procede alla cancellazione dei dati personali attivi, fatti salvi obblighi di legge.

12.2 Su richiesta tempestiva del Titolare, ONE restituisce o esporta i dati nei formati standard disponibili. Migrazioni, conversioni o assistenza ulteriori sono disciplinate dal Contratto e possono essere a pagamento.

12.3 Le copie residue nei backup sono eliminate secondo i cicli ordinari di rotazione indicati nell'Allegato B e, fino alla cancellazione, restano isolate e non sono ulteriormente trattate salvo necessità di ripristino o obbligo di legge.

13 Responsabilità

13.1 Ciascuna Parte risponde delle violazioni ad essa imputabili secondo il GDPR e la normativa applicabile. I rapporti con gli interessati e i diritti di regresso restano disciplinati dall'art. 82 GDPR e dalle norme inderogabili.

13.2 Nei rapporti interni tra le Parti, la responsabilità contrattuale di ONE derivante dal presente DPA è soggetta ai limiti e alle esclusioni previsti dall'art. 15 delle Condizioni Contrattuali Centralizzate, salvo dolo, colpa grave o altra responsabilità non limitabile per legge. Il DPA non introduce massimali autonomi o cumulativi.

13.3 Nessuna disposizione costituisce garanzia di conformità del Titolare ai propri obblighi privacy. Il Titolare resta responsabile della liceità delle finalità, delle basi giuridiche, delle informative, dell'esercizio dei diritti e delle istruzioni impartite a ONE.

14 Modifiche del DPA

14.1 Le modifiche del presente DPA che incidono sugli obblighi ex art. 28 sono comunicate direttamente al Titolare e richiedono accettazione secondo le modalità contrattuali applicabili; la mera pubblicazione sul sito non è sufficiente a renderle efficaci nei rapporti in corso.

14.2 Gli aggiornamenti dell'Allegato C relativi ai Sub-responsabili seguono la procedura dell'art. 7 e non richiedono una nuova sottoscrizione dell'intero DPA.

15 Legge e foro

15.1 Si applicano legge e foro previsti dalle Condizioni Contrattuali Centralizzate, ferme le competenze inderogabili delle Autorità di controllo e dell'autorità giudiziaria previste dalla normativa privacy.

A Allegato A - Dettagli del trattamento

Voce	Descrizione
Oggetto	Erogazione dei Servizi SaaS/API indicati nell'Order Form, inclusa KORE ove attivata.
Natura	Raccolta/ricezione, registrazione, organizzazione, conservazione, consultazione, estrazione, elaborazione, trasmissione, comunicazione su istruzione, cancellazione.
Finalità	Esclusivamente quelle necessarie all'erogazione delle funzionalità acquistate e descritte nell'Order Form.
Interessati	Clienti e potenziali clienti del Titolare; referenti; Utenti autorizzati; altre categorie indicate nell'Order Form.
Dati	Anagrafici, contatto, identificativi, documentali, lavorativi/reddituali, finanziari/creditizi ove previsti, conversazioni, dati tecnici e log, ulteriori dati necessari al Servizio.
Categorie particolari	Non raccolte come finalità autonoma. Possono essere incidentalmente contenute nei documenti trasmessi dal Titolare o dall'interessato. Il Titolare istruisce ONE a trattarle esclusivamente nella misura necessaria al Servizio e garantisce la sussistenza dei presupposti ex artt. 6 e 9 GDPR.
Dati relativi a condanne penali e reati	Non previsti, salvo diversa indicazione del Titolare nell'Allegato A-bis dell'Order Form con indicazione della relativa base normativa.
Durata	Durata dei Servizi e periodo di uscita/cancellazione di cui all'art. 12, salvo termini specifici indicati dal Titolare.
Retention applicativa	Stabilita dal Titolare per tipologia di pratica/servizio e indicata nell'Allegato A-bis dell'Order Form.

B

Allegato B - Misure tecniche e organizzative

- cifratura delle comunicazioni mediante protocolli di trasporto sicuri e cifratura a riposo secondo le funzionalità dei servizi infrastrutturali utilizzati;
- credenziali nominative, autenticazione forte per accessi amministrativi ove applicabile e profilazione per ruolo;
- principio del minimo privilegio e revisione delle abilitazioni secondo procedure organizzative;
- segregazione logica dei dati tra clienti;
- logging tecnico e tracciabilità delle operazioni rilevanti, con conservazione dei log tecnici per periodi definiti in funzione delle finalità di sicurezza e diagnostica;
- database in configurazione multi-AZ, backup automatici con ripristino point-in-time fino a 14 giorni e snapshot manuali, e procedure di continuità secondo l'architettura del Servizio; eventuali RTO/RPO sono garantiti solo se espressamente contrattualizzati;
- monitoraggio operativo, gestione incidenti e procedure di escalation;
- gestione delle modifiche e degli aggiornamenti applicativi;
- misure organizzative di riservatezza e formazione del personale;
- gestione dei Sub-responsabili e verifica delle garanzie contrattuali applicabili.

Ulteriori informazioni sulle misure di sicurezza sono pubblicate nella sezione Sicurezza del Trust Center KORE.

C

Allegato C - Sub-responsabili e trasferimenti

C.1 Sub-responsabili autorizzati

Soggetto	Servizio	Paese/regione di trattamento	Trasferimento Capo V / garanzia
Amazon Web Services EMEA SARL	hosting, database, cache, storage, backup, monitoraggio	UE - Francoforte (eu-central-1)	trattamento nello SEE; per eventuali accessi extra SEE: EU-US Data Privacy Framework / Clausole Contrattuali Tipo

Soggetto	Servizio	Paese/regione di trattamento	Trasferimento Capo V / garanzia
Amazon Web Services EMEA SARL - Amazon Bedrock	modelli di intelligenza artificiale per l'agente conversazionale e le funzioni AI della Piattaforma	regioni dell'Unione Europea (inferenza EU cross-region, endpoint Milano, eu-south-1)	come sopra; i dati non sono utilizzati per l'addestramento dei modelli
Amazon Web Services EMEA SARL - Amazon SES	invio email e campagne email	UE	come sopra
Gupshup Inc.	Business Solution Provider WhatsApp / messaggistica	Stati Uniti, UE e Asia (inclusa India)	Stati Uniti: EU-US Data Privacy Framework; India e altri Paesi terzi: Clausole Contrattuali Tipo o altro meccanismo valido ai sensi del Capo V GDPR, con valutazione del trasferimento
Cooabit S.r.l., Via G. Bruno n. 7, 20154 Milano, P. IVA 11613060968	OCR ed estrazione dati da documenti, tramite i propri sub-responsabili Amazon Web Services e Google Cloud (modelli Gemini)	UE - AWS Irlanda (eu-west-1) per server e database, AWS Milano (eu-south-1) per lo storage temporaneo cifrato dei documenti; Google Cloud in location UE	nessun trasferimento extra SEE; documenti, file intermedi e dati estratti cancellati automaticamente dall'infrastruttura Cooabit entro 30 minuti dal completamento dell'elaborazione; contenuti inviati al modello AI conservati da Google fino a 55 giorni al solo fine di monitoraggio anti-abuso, senza utilizzo per l'addestramento; log applicativi conservati 90 giorni e log di sicurezza e audit 400 giorni, senza contenuti documentali

I codici OTP per la firma elettronica sono inviati tramite i Sub-responsabili sopra indicati (Amazon Web Services e Gupshup). Il servizio di invio PEC non è attualmente attivo; la sua eventuale attivazione seguirà la procedura di cui all'art. 7.

C.2 Soggetti della supply chain che non operano come Sub-responsabili

Soggetto	Attività	Ruolo privacy
Meta Platforms Ireland Ltd (WhatsApp Business Platform)	canale WhatsApp	Sub-responsabile di Gupshup per l'invio e la ricezione dei messaggi tramite la WhatsApp Business Platform; autonomo titolare per i trattamenti svolti per finalità proprie ai sensi dei termini WhatsApp
CRIF e altri Sistemi di Informazione Creditizia	consultazione SIC su istruzione del Titolare	Autonomo titolare - destinatario su istruzione del Titolare
Compagnie assicurative indicate dal Titolare	valutazione e assunzione del rischio assicurativo	Autonomo titolare - destinatario su istruzione del Titolare

Fine del Data Processing Agreement ONE / KORE - Versione 1.1
ONE / KORE - Data Processing Agreement v1.1 - [data di pubblicazione]